19 Appendix M11 – IT Infrastructure

19.1 Introduction

EU Annex 11 [32] states: *"The application should be validated; IT infrastructure should be qualified."* However, due to the dynamic nature of infrastructure, it is best to think of achieving and maintaining a qualified state as an exercise of managing to compliance. This state of control is the cornerstone of qualification as expected in EU Annex 11.

A controlled IT infrastructure is a prerequisite for ensuring that GxP applications are managed in a state of control. Infrastructure plays a significant role in ensuring applications are on a stable platform with reliable required communications. The IT infrastructure supports application performance and availability as well as the integrity, availability, security, and confidentiality of data. Many of the processes required to ensure this rely on some aspects of infrastructure management, such as cybersecurity, load balancing, backup and restore, disaster recovery, etc.

19.1.1 Changes from GAMP 5 First Edition

This appendix was originally identified as Appendix S5. It dealt only with managing quality in an outsourced environment. While this is certainly still an important aspect, infrastructure management is a process that inevitably involves both internal and external processes. This significantly revised appendix applies current risk-based thinking on good practice for managing infrastructure that resides within a regulated company's own facilities as well as ensuring those of external suppliers, for example, for cloud-based suppliers of Infrastructure as a Service (IaaS), Platform as a Service (PaaS), and Software as a Service (SaaS) [20].

As a result, Appendix S5 has been withdrawn and the revised material renamed as Appendix M11.

19.1.2 Further Reading

Managing IT infrastructure is discussed in more depth in the *ISPE GAMP Good Practice Guide: IT Infrastructure Control and Compliance (Second Edition)* [49], and additional background for managing outsourced services can be found in Appendix M6 in this Guide. Infrastructure management processes have become more automated, reducing the incidence of human error by substituting verified automated processes for manual ones. This topic is still evolving, as IT infrastructure management embraces increased automation and de-emphasizes reliance on paper records only.

19.2 Principles and Assumptions

19.2.1 Scope of Infrastructure Qualification

This Document is licensed to

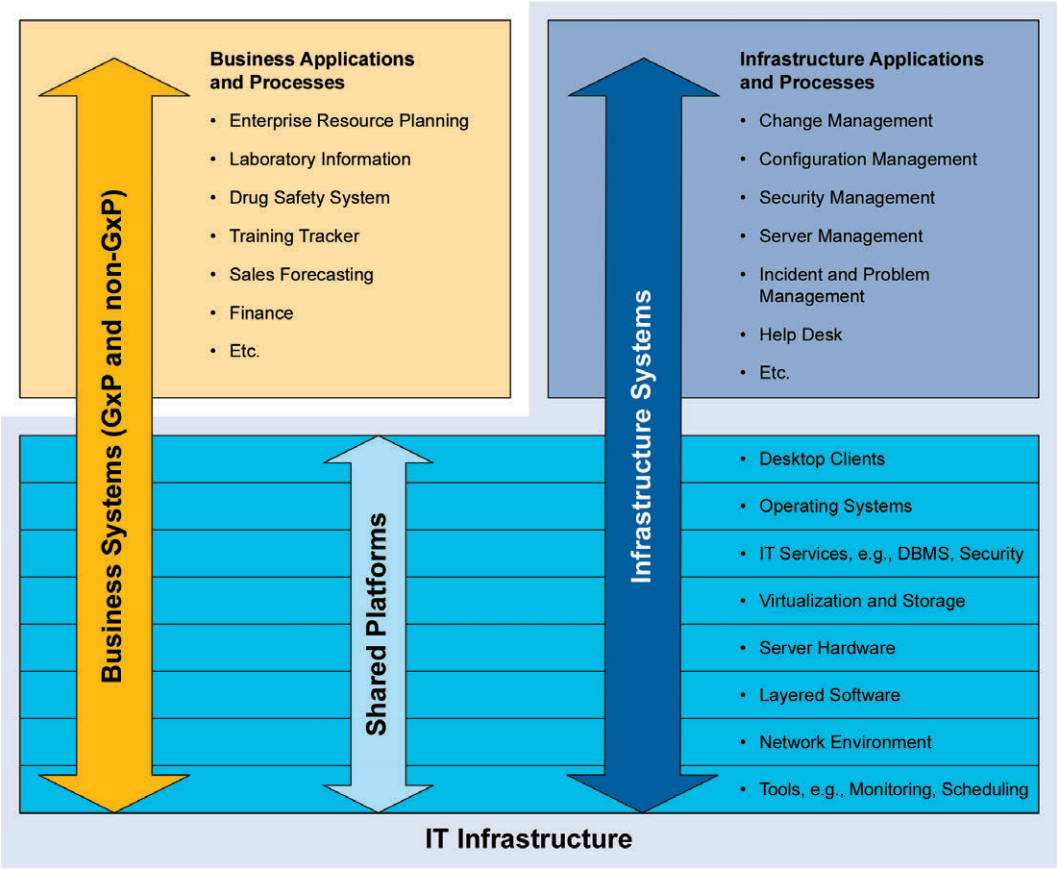
Figure 19.1 illustrates the scope of infrastructure considerations and how some of the business processes within IT need to be considered as part of a qualified infrastructure.

Mr. Xin Cheng
Shanghai, Qingpu District
ID number: 1096946

Downloaded on: 7/29/22 10:02 PM

For individual use only. © 2022 ISPE. All rights reserved.

Figure 19.1: Relationship of IT Infrastructure and Processes with Business Systems and Processes
Adapted from ISPE GAMP Good Practice Guide: Enabling Innovation – Critical Thinking, Agile, IT Service Management [20].



19.2.2 Infrastructure Qualification versus Application Validation

A regulated company approaches implementing an application to meet their business needs by developing requirements, configuring the application as necessary, performing risk-based verification as needed, establishing appropriate operational controls, and managing it to a controlled state (these combined efforts comprise validation). This is far simpler for most, but not all infrastructure elements. The company has no input into the design and manufacture of components such as servers, network switches, etc., which are effectively off-the-shelf purchases. After the initial component build has been verified to perform acceptably, new components are simply configured to the standard, and testing of each build may be extremely limited (e.g., verifying that a network node can reach another node) or absent (e.g., by using a review-by-exception approach – see Section 19.2.4). Some components are initially verified but may also require additional configuration and subsequent verification of that configuration.

This Document is licensed to
Mr. Zhi Chang
Shanghai, Qingpu District
ID number: 1066046
Downloaded on: 7/29/22 10:02 PM

Infrastructure, which is continually evolving to meet business needs, must be managed to a controlled state. Both confirmation of components' fitness for purpose and management to a controlled state are likely to involve automated processes.

The greater dynamism of the infrastructure, combined with the widespread use of standardized components that use the "one qualification, many implementations" model is the primary difference highlighted as noted above in EU Annex 11 [32].

Note also that infrastructure software is GAMP Category 1, and as such is qualified, not validated.

For individual use only. © 2022 ISPE. All rights reserved.

19.2.3 Component-Based Nature of Infrastructure

Infrastructure is generally comprised of many instances of certain standard components. For example, companies have many network switches, servers, and storage devices. These components are generally deployed in standard basic configurations. If these standard configurations have been demonstrated to perform acceptably, it is a reasonable assumption that additional components deployed in those configurations also will. This indicates that IT infrastructure presents lower risk than applications.

19.2.4 Infrastructure Automation

Infrastructure as Code (IaC) is a means of provisioning and deploying infrastructure using DevOps processes. IaC enables organizations to automate the provisioning of infrastructure, reducing the risk of human errors. Infrastructure code is subject to configuration management ensuring that all code changes are traceable. Infrastructure code development is subject to risk-based software development practices that ensure code is developed in accordance with a life cycle approach including verification prior to deployment. Configuration management and deployment tools allow for review and authorization prior to deployment of new/updated configurations, use of templates to ensure maintenance of consistent configurations across the infrastructure landscape, and monitoring of the configuration baseline to detect unauthorized changes. A further benefit to this being that a “one qualification, many deployments” approach can be taken, particularly with standard virtualized environments.

The configuration of standard infrastructure components is part of the creation of basic building blocks that are the foundational platforms for applications. Such configuration processes are readily automated. For example, an out-of-the-box server can have the operating system, middleware, layered software, and security policies loaded via an automated process. There may be multiple similar automated build scripts, for example, to build servers with different database engines. These automated builds can produce various log files or even perform simple automated tests that demonstrate a successful build, and a review-by-exception process similar in principle to that used for pharmaceutical manufacturing obviates the need for further verification. Critical thinking must be applied when deploying such “standard” environments, however. In some cases, greater control may be warranted; for example, cybersecurity risks may differ from one example to the next, which might merit hardening of the security for an otherwise standard component.

19.2.5 Tools

There are many automated tools that help IT to operate in an effective and controlled manner, for example, a Configuration Management Database (CMDB), or scheduling tools that initiate routine processes like backup, data transfers, or ETL[11]. There are also service management tools that ensure adherence to IT quality processes and standardization of information supporting these processes, such as IT service management tools that process and catalog customer service requests, incidents, changes, problems, and other services. Such tools do not require validation, although proper installation, use, and a state of control for them is required. (See Appendix D9.)

This Document is licensed to
Mr. Xin Cheng
Shanghai Chinese Pharmaceuticals
Co. Ltd. - 2022-12-22 2:02 PM

19.3 Risk Management and Infrastructure

Given that IT departments service the entire enterprise and not just GxP areas, cases may occasionally arise where a risk to the enterprise as a whole requires a change that cannot go through a time-consuming change control process that includes sequential evaluation, approval, testing, and release. For example, if a zero-day security vulnerability[12] is recognized that threatens serious harm to the regulated company if it is exploited, remediation will be done as rapidly as possible. It is usually the case that risk from cybersecurity threats directly correlate to the data integrity considerations of GxP risk. See Section 19.4 for further discussion of QA roles.

[11] ETL is a tool that extracts, transforms, and loads data.
[12] A zero-day vulnerability means there are known exploits of the security flaw.

For individual use only. © 2022 ISPE. All rights reserved.

IT risk priorities therefore tend to focus on risks to system availability, performance, and information security. These priorities, however actually do address GxP concerns: applications are available when needed, they work well, and there is data integrity.

As Reid and Wyn [52] observed:

> *"Threats to the IT Infrastructure environment largely come from cyberattacks, unauthorized access, system and component failure, or inadequate re-source provisioning (storage capacity, processing capacity). These risks are continuous, and it is therefore imperative that the currency of IT infrastructure controls is maintained (e.g., through security patching) and monitoring is in place to provide early detection of any threat. IT infrastructure design incorporates a high degree of resilience that mitigates both single-point and complete failure."*

Another risk may come from authorized but uninformed decisions to alter system-wide parameters that may affect GxP systems or data. This highlights the need for training and SME oversight of the infrastructure staff.

Because of the high degree of resilience noted above, the GxP risk for properly managed infrastructure is relatively low; however, with many organizations adopting cloud-first strategies, the evaluation of "as a Service" vendors can influence risk both at the system and enterprise levels. This can be a starting point for risk management considerations for applications, although it is possible that non-standard implementations where a hostile environment or a single point of failure could raise infrastructure risk.

19.4 The Role of Quality

The quality unit can play an effective role in the development and manufacture of medicinal products and medical devices largely because staff are familiar with the operation of those areas. While they may not be SMEs, they typically understand the processes. This is not the case for IT. Add to this that infrastructure groups manage many non-impact changes and that the risk to patients for IT infrastructure decisions is typically extremely low, and heavy quality unit involvement in infrastructure is unwarranted and potentially extremely inefficient. There may be exceptions where greater involvement could be warranted: for example, SaMD may have greater potential direct-patient impact if there is a failure of underlying infrastructure.

The preamble to the US FDA 21 CFR Parts 210/211 [53] states:

> *"Functions that are properly those of the engineering department or other specialized units because of their unique training and experience should not be duplicated or usurped by the quality control unit. Where expertise is in other units, the responsibility of the quality control unit is to assure that such expertise has been utilized."*

This is not to say that there should be no quality oversight. There should be an agreement between QA and IT system owners on an IT quality framework. This should define what fitness for purpose means for infrastructure. It is advisable that IT organizations establish an internal IT Quality (ITQ) function. This function should oversee IT processes to ensure that they support a state of control, and they should be familiar enough with GxP expectations to know when the quality unit should be involved in a decision. For example, it may make sense for them to be involved in a change of database engines used in multiple GxP applications, or when a major operating system upgrade is undertaken. The quality unit should not need to worry about less impactful changes like microcode updates or the installation of new virus definitions. If the quality unit is involved, their overall aim should be to ensure that quality processes are followed and that there is adequate evaluation of risk and controls. They should not be involved in the technical solution or decisions because they most likely lack the expertise.

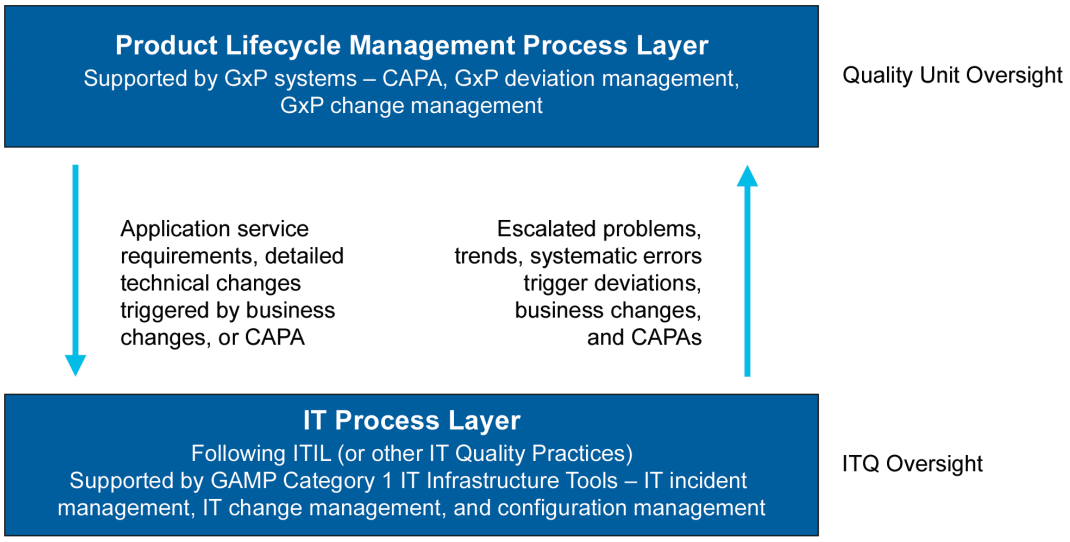
This Document is licensed to
Shanghai Qingpu District
IP address: 180.96.6.
Downloaded on: 7/29/22 10:02 PM

There should be cooperative interaction between ITQ and the quality unit.

Figure 19.2 shows the relationship between the product life cycle quality processes and ITQ processes.

For individual use only. © 2022 ISPE. All rights reserved.

Figure 19.2: Interaction of ITQ and the Quality Unit [20]



There will be many changes and other activities that only merit verification by an SME; allocating additional storage space is a good example where the risk is negligible and process efficiency should be the prime consideration. In general, far more routine IT changes fall into this category as opposed to those meriting formal quality unit review. IT procedures should clearly define circumstances where quality unit involvement is warranted. These should be limited to situations where significant risk to applications or data is possible, for example, for significant functional application upgrades or overhaul of the core database engine.

Responsibility for any quality decision should be procedurally defined.

19.5 IT Processes in Scope for Infrastructure Qualification

Several processes managed by IT are key to ensuring a controlled state of applications. There are excellent resources available for management of these IT business processes, such as ITIL[13]. Some of these processes will require input from the business users of applications. For example, business input is needed to define expected service levels: help desk hours, response times, etc. In some cases, costs may need to be negotiated.

19.5.1 Security Management

This Document is licensed to
Mr. Jun Cheng
Shanghai, Qingpu District
ID number: 1096940
Downloaded on: 7/29/22 10:02 PM

Critical to data integrity within the GxP scope are several security-related processes:

- Access control and password management – ensuring that only authorized people have access to applications and data, including a process such as periodic review to ensure that individuals no longer needing access have their privileges revoked
- Management of administrative access – to minimize elevated privileges
- Cybersecurity – including data segregation, firewalls, intrusion detection and prevention, antivirus, and expediting management of vulnerabilities
- Management of encryption key(s)

[13] For an overview of ITIL see www.ibm.com/cloud/learn/it-infrastructure-library [54].

For individual use only. © 2022 ISPE. All rights reserved.

It should be noted that IT will approach data integrity with a generic enterprise-wide solution unless they are informed that additional protections are needed. It is the responsibility of the business process owner and/or the data owner, possibly with assistance from the quality unit, to assess the supporting infrastructure processes and request modification if necessary.

19.5.2 Backup and Recovery

Processes need to include analysis of the required frequency of backup (both of applications and of the data) to meet business needs; the process for executing backup; and the process for recovering a backup copy, including who is authorized to request a recovery. It is vital for GxP applications that both Recovery Point Objectives (RPO, which dictates the frequency of backups) and Recovery Time Objectives (RTO, which dictates the interval between system failure and recovery), are defined and testable at a frequency commensurate to the system risk and agreed by the business owner. All backup processes should be periodically verified to demonstrate that they are recoverable and meet the current business need. Problems or failures should be reported back to the data owner. It is an obvious, yet often overlooked point, that the importance of periodic testing is to ensure that problems are found proactively, and not when the integrity of GxP data is compromised by a failure.

19.5.3 Archive and Restore

Processes should include how and when data (including metadata) is moved to an archive, how archived data can be accessed and by whom, and how to destroy data no longer needed, including authorization to do so. Data needs to be readable throughout the retention period. This can require attention from both the business area and infrastructure support, including for issues like data migration or support for older versions of a database engine.

19.5.4 Change Management

Change management within the IT infrastructure requires a controlled and defined process; however, it cannot be a direct parallel to change-control processes for GxP applications. Infrastructure changes should be managed at the IT process layer and not at the product life cycle management process layer. For most infrastructure changes, GxP risk is extremely low. There are also a relatively large number of changes within infrastructure, some of which will be done on a routine schedule, and are best managed through other processes (see below). The role of the quality unit versus ITQ as noted in Section 19.4 should be defined for change approval.

There should be differentiation between actual changes and activities such as repair (including like-for-like replacement), maintenance, and system administration, which will be managed under their own processes. Further, the ITIL [5] concept of standard changes can be extended into GxP infrastructure management. A list of pre-agreed changes that IT can make without the need for additional oversight can maintain the infrastructure's compliant state while ensuring operation efficiency. Provisions for emergency changes should also be made. For example, when a database administrator notices that an application needs more table space, allocation of that does not constitute a change.

This Document is licensed to
Mr. Xin Cheng
Shanghai, Qingpu District
A-Mabel Medical
Downloaded on 7/20/22 10:02 PM

19.5.5 Configuration Management

Configuration management is both a regulatory expectation and necessary for running an effective IT operation. Configuration management encompasses both the configuration of applications running on infrastructure as well as the hardware and infrastructure software itself. In a modern IT environment, it is impractical to try to achieve this without a CMDB.

19.5.6 Disaster Recovery and Business Continuity Planning

Clearly a shared responsibility with business process owners, the IT infrastructure team needs to ensure that their disaster response is adequately planned, resourced (both facilities and staff), and tested. This may include leveraging cloud resources.

For individual use only. © 2022 ISPE. All rights reserved.

The roles and responsibilities of business and IT groups should be defined, and the business process owners of the GxP application should understand the benefits, constraints, and limitations of the agreed IT service delivery. This is a regulatory expectation, e.g., in EU Annex 11 Section 3.1 [32].

GxP process owners and system owners need to understand that this is another case where enterprise risk priorities may supersede GxP priorities. While it may seem counterintuitive to prioritize restoring manufacturing after finance systems, if the business may fail without the latter, they must be handled first. There should be an enterprise-level prioritization for this, and it should be shared with all involved parties. If there is a potential public health impact, for example, a drug shortage, that should be part of the consideration for prioritization.

DR and BCP processes should be defined, documented, and practiced. See Appendix O10 for further discussion.

19.5.7 Other IT Processes

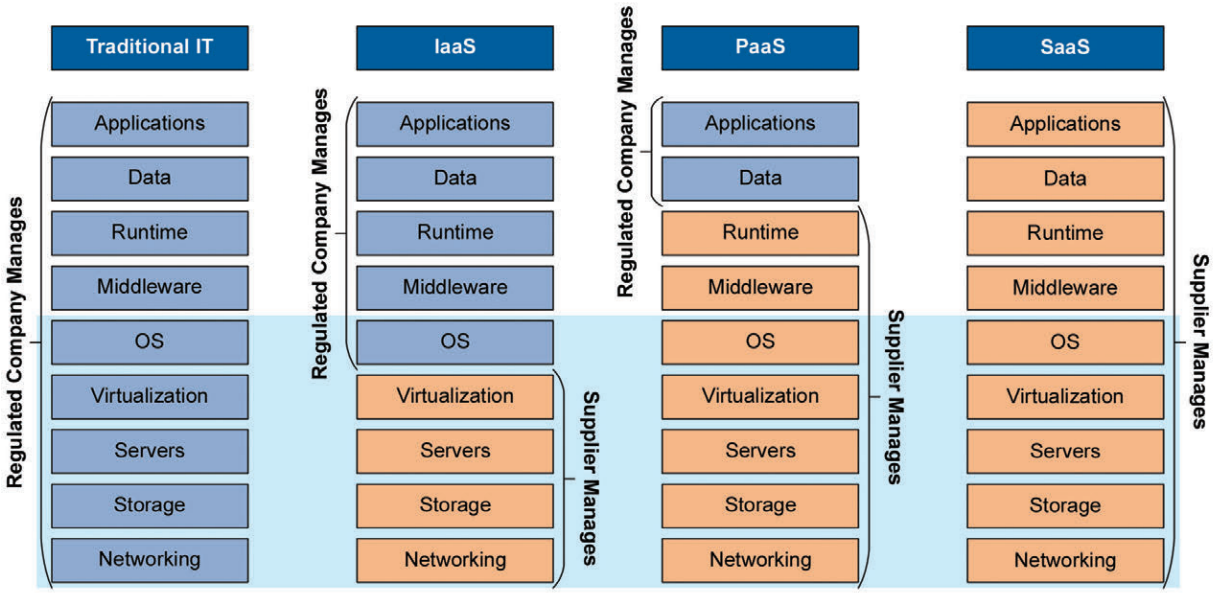
There are other processes that are often managed by IT infrastructure groups that are not limited in scope to infrastructure but do bear some relevance. Examples include:

- IT service desk
- Incident and problem management (including CAPA where relevant)
- Service level management
- Asset management

19.6 Cloud Infrastructure

Any use of cloud resources brings infrastructure qualification considerations into scope. Figure 19.3 shows the various levels of delegation of control to the supplier for IaaS, PaaS, and SaaS deployments. In all cases, however, the infrastructure management and control expectations are constant, and are represented by the blue background. In both PaaS and SaaS, all infrastructure activities are delegated to the supplier, while it is shared in IaaS, and of course resides solely with the regulated firm, for a traditional deployment in their own data center.

Figure 19.3: Customer and Supplier Responsibilities for Cloud Implementations (infrastructure within blue background) [20]



For individual use only. © 2022 ISPE. All rights reserved.

The difficulty with cloud suppliers lies in the fact that, with very few exceptions, they are not GxP regulated. This does not mean that they are universally unsuited to host GxP applications. The core question is whether they have an adequate state of control over their infrastructure. This can be determined via an effective supplier evaluation process (see Appendix M2), a robust set of contractual agreements on service levels, quality, and monitoring. Such agreements should have agreed escalation procedures for incidents and problems.

When outsourcing a GxP system to a third party it is vital to understand where the data is resident and to ensure that the service provider has taken adequate steps to ensure their delivery is robust. A SaaS or PaaS provider, as an example, can only offer as much uptime and performance as their own infrastructure provider can accommodate. The higher the risk of a cloud-delivered GxP application, it is expected that its associated infrastructure is more robust (regional mirroring versus tape backups as an example).

Data integrity should be a factor in any decision to manage GxP data in the cloud. Considerations involving infrastructure include:

- Access management: What are the implications (if any) if supplier staff sees data?
- Encryption: If data (in motion and/or at rest) is encrypted, who manages the key?
- DR: What happens if the cloud supplier has a major incident? RTO and RPO must be agreed.
- Certifications: Which (if any) certifications does the “as a Service” provider hold? e.g., ISO 27001 [44], SOC 1, SOC 2 Type 1 or Type 2 [55], HITRUST® [56], etc.
- Frequency of vulnerability scans and third-party penetration tests
- Local, regional, and global redundancies and segregation
- Deployment model and service model compatibility with the level of GxP risk

Cloud service suppliers are not GxP regulated, and it is the accountability of the regulated organization using such services to ensure that quality processes provide an equivalent level of assurance that patient safety, product quality, and data integrity are protected.

19.7 Continual Improvement

For all IT infrastructure, but especially for cloud implementations, there should always be the question: “What could we be doing better?”

Key processes should be monitored by the service provider and adherence to SLAs agreed by the regulated customer, along with dialog between the parties as to the areas that need improvement, are performing adequately, or are working very well. Including specific Key Process Indicators (KPIs) in the monitoring is recommended.

This Document is licensed to
Shanghai, Qingpu District
ID number: 1096946
Downloaded on: 7/29/22 10:02 PM

For individual use only. © 2022 ISPE. All rights reserved.

20 Appendix M12 – Critical Thinking

20.1 Introduction

This appendix discusses the concept of critical thinking to proactively optimize the approach taken to ensure quality and compliance of computerized systems (i.e., better development, testing, operation, and maintenance) within the context of the business processes they support. Further detailed discussion about critical thinking can be found in the *ISPE GAMP Good Practice Guide: Enabling Innovation – Critical Thinking, Agile, IT Service Management* [20] and *ISPE GAMP Guide: Records and Data Integrity* [35].

While GAMP 5 promotes a risk-based approach to ensuring fitness for intended use, some practitioners do not apply sufficient thought to ensure the approach they are taking is customized and proportionate to the needs of different systems. The use of rigid tables, overly prescriptive templates, and tick-in-the box methods impedes critical thinking and could inhibit innovation and the adoption of new technologies. Wasting time and effort on non-value-added activities can lead to insufficient or excessive work with potential budget overspend and delays, and may reduce focus on more valuable and essential quality activities.

20.1.1 Changes from GAMP 5 First Edition

This is a new appendix.

20.2 Scope

Critical thinking should be applied in a holistic manner to the entirety of the business process that the computerized system supports. The role of ancillary equipment and interfaces should be included in the scope of implementation, validation, and operational activities to avoid missing potential risks to patient safety, product quality, and data integrity.

The interplay between system and data life cycles should also be subject to critical thinking and QRM. Multiple systems may be involved in supporting a single data life cycle. For example, data may be created and processed in one system, reported and used to make GxP decisions in an ERP system, and then archived for the retention period in another.

Operational compliance and data integrity is highly dependent upon personal behaviors. Critical thinking will play a key role in addressing human factors through effective behavioral, procedural, and technical controls, recognizing that the strength of quality culture varies across different locations driven in large part by geographic values and local historical context.

Interdependencies with suppliers and service providers, including in-house suppliers, are a further consideration within the scope of critical thinking. The supplier's application of their own QMS to the development and release of their software/service can influence business process risks and whether or not the software/service functionality is fit for the regulated company's intended use.

This Document is licensed to
Li Xin Yuan
Shanghai, Qingpu District
ID number: 1096946

Downloaded on: 7/29/22 10:02 PM

For individual use only. © 2022 ISPE. All rights reserved.

20.3 Guidance

20.3.1 Facilitating Critical Thinking

For critical thinking to be used successfully, the QMS and validation policy must permit and encourage its application. Examples of this are:

- Where templates are provided, they are used as an aide memoire to ensure the relevant areas for the particular system are covered rather than as a form to be completed.

- An addition or alternative to templates can be provided to cover essential elements that must be captured or defined as part of the activity, leaving the format and structure open to optimization for the particular system or tool used.

Sections 20.3.2 – 20.3.12 provide examples of how critical thinking can be applied to improve efficiency for the activities within the system life cycle.

20.3.2 Planning

A business process maybe supported by multiple computerized systems. Planning may involve adding a new system, updating an existing system, or consolidating multiple systems into a single enterprise system. When planning implementation, a full understanding of the regulated aspects of the process to be supported, including the intended use of data within the process, is fundamental.

Critical thinking should be applied to understand the implementation risks as well as functional risks to patient safety, product quality, and data integrity. Business process flowcharts illustrate the business activities, decision points, and subprocesses, while the data flow diagrams identify the creation, processing, review, use, and archiving of data. The data flow diagram should identify the primary record for regulated data if the data resides in more than one system or location. Together these diagrams help in the understanding of the business process to identify risks to patient safety, product quality, and data integrity associated with the process. Data integrity cannot be achieved without a complete understanding of the data flow. Developing business process maps and data flow diagrams is described in *ISPE GAMP Guide: Records and Data Integrity* [35] and the *ISPE GAMP RDI Good Practice Guide: Data Integrity by Design* [36]. Planning for individual systems is discussed in Section 4.2.1 of this Guide.

Examples of planning using critical thinking include [20]:

- Utilizing business process mapping and data flow diagrams to understand where the computerized system will fit in the process, what regulated data will pass through it, and what part of the regulated data's life cycle the system will support. The process maps and data flows do not need to be contained within a particular document but should be current and accessible and referenced by the system and life cycle information when needed. The use of process mapping and diagramming tools is encouraged.

- Defining consistent nomenclature for use in the process to facilitate data transfer, trending, and analytics.

- Selecting a solution that best fits the business requirements minimizing configuration and customization, recognizing that it may be more pragmatic to adjust the business process to fit a standard application.

- Understanding the interfaces needed to other systems, and what standard interfaces are available versus developing new interfaces (with their additional test and management burden).

- Planning for how the system should respond in an error or failure situation and how it can recover from such a situation, as well as how it should behave during normal operation.

This Document is licensed to
Mr. Xin Cheng
Shanghai, Qingpu District
11-Feb-2025 10:06:06 AM

For individual use only. © 2022 ISPE. All rights reserved.